

### Summary

The analysis identified two hosts exhibiting strongly anomalous behavior. WS-007 (10.10.20.16) produced 1,600 outbound HTTPS connections to the external host 185.203.116.77 over a 28.9-hour period, with a mean inter-arrival delta of 65.04 seconds and a standard deviation of only 6.18 seconds a coefficient of variation of 9.5%, consistent with automated, software-driven periodicity rather than human activity. WS-033 (10.10.20.42) generated 260 NXDOMAIN responses across 260 unique, algorithmically random-looking domain names during a 77-minute burst on the night of February 4, 2026 behavior consistent with a Domain Generation Algorithm (DGA) iterating through candidate C2 hostnames.

Cross telemetry correlation confirms that WS-007 first resolved the domain vbx92-z8lq.com to 185.203.116.77 at 09:15:00 on February 3, and initiated its first beacon connection 58 seconds later, establishing a DNS-to-flow causal chain consistent with implant initialization and C2 check-in behavior.

**Key Finding:** Two hosts WS-007 and WS-033 exhibit behavioral signatures strongly indicative of active C2 communication and DGA-based infrastructure discovery. Attribution is behavioral, not signature-based.

### Telemetry Environment & Data Hygiene

#### Dataset Characteristics

Two telemetry sources were provided, spanning a seven-day observation window. Both datasets required timestamp normalization before any time-series modeling could be performed.

| Dataset   | Records | Date Range               | Unique Hosts | Format Notes                         |
|-----------|---------|--------------------------|--------------|--------------------------------------|
| flows.csv | 19,601  | 2026-02-01 to 2026-02-07 | 46 src IPs   | ISO format (YYYY-MM-DD HH:MM:SS)     |
| dns.csv   | 9,860   | 2026-02-01 to 2026-02-07 | 40 src IPs   | MM/DD/YYYY HH:MM — minute resolution |

#### Data Hygiene Procedures

#### Traffic Composition Overview

| Protocol / Port  | Flow Count | % of Total | Context                                     |
|------------------|------------|------------|---------------------------------------------|
| TCP/443 (HTTPS)  | 9,425      | 48.1%      | Dominant protocol — includes beacon traffic |
| UDP/53 (DNS)     | 3,368      | 17.2%      | DNS query traffic visible in flow layer     |
| TCP/445 (SMB)    | 2,420      | 12.3%      | Internal AD/file share — expected           |
| TCP/80 (HTTP)    | 2,297      | 11.7%      | Unencrypted web — expected mix              |
| TCP/3389 (RDP)   | 1,091      | 5.6%       | Remote desktop — warrants monitoring        |
| TCP/389, 88, 636 | 763        | 3.9%       | LDAP, Kerberos, LDAPS — AD auth             |

| Protocol / Port     | Flow Count | % of Total | Context                               |
|---------------------|------------|------------|---------------------------------------|
| TCP/1433<br>(MSSQL) | 237        | 1.2%       | Database access — expected enterprise |

## Detection Task A : Beaconing Detection

### Scenario Context

Modern Command-and-Control (C2) frameworks, Cobalt Strike, Metasploit, Sliver, Havoc, and their derivatives, employ periodic callback mechanisms to maintain operator connectivity with implanted hosts. These callbacks are characterized by statistical regularity that distinguishes them from human-driven network activity. Unlike signature-based detection, which fails when adversaries rotate IP addresses or domains (a trivial operation), behavioral detection targets the mathematical properties of the timing signal itself. A C2 implant configured with a 60-second check-in interval will exhibit near-constant inter-arrival times regardless of the destination infrastructure.

The key insight exploited by this detection model is that humans cannot sustain metronomic periodicity, but software can. The coefficient of variation ( $\sigma/\mu$ ) of human-driven web browsing or application traffic typically exceeds 100%. Automated processes operating on fixed sleep timers produce CoV values well below 20%.

### Detection Algorithm

The beaconing detection function implements the following pipeline:

- Group flows.csv by the tuple (src\_ip, dst\_ip, dst\_port). This isolates individual host-to-host communication channels on a per-protocol basis, preventing cross-destination timing contamination.
- Sort each group chronologically and compute inter-arrival deltas:  $\Delta t_i = t_{i+1} - t_i$  expressed in seconds using pandas .diff().dt.total\_seconds().
- Drop the first NaN (no prior event) and all  $\Delta t \leq 0$  (simultaneous events, duplicate log entries).
- Aggregate per group: connection\_count, mean\_delta\_seconds ( $\mu$ ), std\_delta\_seconds ( $\sigma$ , ddof=1 for sample standard deviation as specified in the Startup Guide).
- Apply threshold filters to retain only statistically consistent, high-frequency groups.

### Threshold Design & Justification

| Threshold                | Value     | Behavioral Rationale                                                                                                                                                                                                | False Positive Risk                                    |
|--------------------------|-----------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------|
| Minimum connection_count | $\geq 20$ | Sample sizes below 20 produce statistically unstable standard deviations. A beacon operating at 65-second intervals accumulates 20 connections in just 22 minutes. This eliminates spurious single-session matches. | Background monitoring agents with infrequent check-ins |

| Threshold                  | Value         | Behavioral Rationale                                                                                                                                                                                                                                                              | False Positive Risk                                             |
|----------------------------|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------|
| Maximum std_delta_seconds  | $\leq 30.0$ s | At $\sigma = 6.18$ s, the observed beacon has a CoV of 9.5% — consistent with a fixed sleep timer with minor OS scheduling jitter. Human traffic CoV typically exceeds 100%. A 30s ceiling is deliberately conservative to catch jittered beacons while excluding random traffic. | NTP sync daemons, Windows Update scheduler, AD heartbeat probes |
| Maximum mean_delta_seconds | $\leq 3600$ s | Sub-hourly C2 check-ins are operationally typical. Long-cycle beacons (>1 hour) also exist but are a secondary concern. This threshold reduces false positives from nightly cron jobs and batch processes that coincidentally fire at regular intervals.                          | Weekly scheduled tasks with consistent timing                   |

**Threshold Philosophy:** Lower  $\sigma$  threshold  $\rightarrow$  higher precision, lower recall. An attacker adding  $\pm 20\%$  jitter to a 60s beacon would produce  $\sigma \approx 12$ s still captured. An attacker adding  $\pm 60\%$  jitter produces  $\sigma \approx 36$ s missed. This is an acceptable precision/recall tradeoff for enterprise SOC deployment.

### Beacon Detection Results

Applying the thresholds to 19,601 flow records across 11,269 unique (src\_ip, dst\_ip, dst\_port) groups yielded a single candidate:

| src_ip      | dst_ip         | dst_port | connection_count | mean_delta_seconds | std_delta_seconds |
|-------------|----------------|----------|------------------|--------------------|-------------------|
| 10.10.20.16 | 185.203.116.77 | 443      | 1,600            | 65.042             | 6.184             |

No other group in the dataset approaches these statistical properties. The next-lowest standard deviation among groups with  $\geq 20$  connections belongs to internal SMB heartbeats (std > 15,000 seconds), confirming that the beacon candidate is a true outlier.

### Deep Analysis: WS-007 Beacon Profile

| Metric           | Value                | Interpretation                                                    |
|------------------|----------------------|-------------------------------------------------------------------|
| Source Host      | WS-007 (10.10.20.16) | Enterprise workstation in the user VLAN                           |
| Destination      | 185.203.116.77       | External IP — non-enterprise, no legitimate business relationship |
| Destination Port | 443/TCP              | HTTPS — encrypted, blends into legitimate web traffic             |

| Metric                     | Value                                      | Interpretation                                               |
|----------------------------|--------------------------------------------|--------------------------------------------------------------|
| Connection Count           | 1,600                                      | Sustained over 28.9 hours — persistent, not transient        |
| Mean Interval ( $\mu$ )    | 65.04 seconds                              | ~65-second sleep timer with jitter                           |
| Std Deviation ( $\sigma$ ) | 6.18 seconds                               | Highly consistent — software-driven periodicity              |
| Coefficient of Variation   | 9.5%                                       | Human traffic typically >100% CoV                            |
| Delta Range                | 55s – 75s                                  | $\pm 10$ s jitter band around 65s base period                |
| Bytes Out (mean $\pm$ std) | 477 $\pm$ 103 bytes                        | Small, consistent payload — check-in pattern                 |
| Bytes In (mean $\pm$ std)  | 425 $\pm$ 101 bytes                        | Small server response — no large data exfil in flow metadata |
| Observation Window         | 2026-02-03 09:15:58 to 2026-02-04 14:09:20 | 28.9 hours continuous operation                              |

The byte volume pattern is particularly noteworthy. The outbound payload averaging 477 bytes with a standard deviation of only 103 bytes over 1,600 connections is inconsistent with normal application data transfer, which exhibits high variability. This profile matches a C2 beacon transmitting a fixed-format check-in structure — host identifier, task queue query, and optional command output — on every callback. The symmetric inbound response (425  $\pm$  101 bytes) suggests task responses or small instructions are flowing from the operator infrastructure.

## Detection Task B — NXDOMAIN Burst Detection

### Scenario Context

Domain Generation Algorithms (DGAs) are a family of techniques used by malware to algorithmically produce hundreds or thousands of pseudo-random domain names per day. Only a subset of these domains are registered by the attacker at any given time. The malware iterates through generated candidates, and when a successful DNS resolution is returned, it connects to the newly registered C2 domain. This approach makes infrastructure takedown extremely difficult: if defenders null-route one domain, the next candidate is already in the rotation.

The behavioral signature of DGA activity in DNS telemetry is distinctive: a burst of queries to domains that have never been observed before, almost all returning NXDOMAIN, with domain names exhibiting characteristics of algorithmic generation (high character entropy, alphanumeric mixing, absence of recognizable English words). The windowed analysis approach aggregates this behavior over 15-minute intervals to distinguish isolated lookup failures from systematic bulk querying.

### Detection Algorithm

- Floor timestamps to 15-minute bins using `.dt.floor("15min")` to create consistent, non-overlapping observation windows.
- Group DNS records by `(src_ip, time_bin)` to isolate per-host behavior within each window.
- Aggregate: `total_dns_queries` (count), `nxdomain_count` (sum of `is_nxdomain`), `unique_queries` (nunique of query field).

- Compute  $\text{nxdomain\_ratio} = \text{nxdomain\_count} / \text{total\_dns\_queries}$ . The ratio normalizes for hosts that issue different total query volumes.
- Apply thresholds and return candidate windows sorted by  $\text{nxdomain\_count}$  descending.

### Threshold Design & Justification

| Threshold                            | Value       | Behavioral Rationale                                                                                                                                                                                                                                                            | False Positive Risk                                                       |
|--------------------------------------|-------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------|
| Minimum $\text{total\_dns\_queries}$ | $\geq 10$   | A single misconfigured application could produce one NXDOMAIN with ratio = 1.0. Volume is required to distinguish systematic automated behavior from isolated failures. DGA campaigns typically produce dozens of queries per minute.                                           | Misconfigured DNS stub resolvers with one broken domain                   |
| Minimum $\text{nxdomain\_count}$     | $\geq 5$    | Absolute count floor prevents small-sample ratio inflation. 5 failures in a 15-minute window is anomalous but achievable by broken app configs. The ratio filter in combination makes this meaningful.                                                                          | Applications with expired CDN domains or split-brain DNS misconfiguration |
| Minimum $\text{nxdomain\_ratio}$     | $\geq 0.50$ | Any legitimate host should resolve the majority of its queries successfully. Enterprise DNS failure rates during normal operations are typically below 5–10%. A majority failure rate (>50%) is a strong anomaly signal that is difficult to explain through normal operations. | Enterprise domain migrations, application rollouts with stale DNS records |

### NXDOMAIN Burst Detection Results

| src_ip      | time_bin            | total_dns_queries | nxdomain_count | nxdomain_ratio | unique_queries |
|-------------|---------------------|-------------------|----------------|----------------|----------------|
| 10.10.20.42 | 2026-02-04 01:15:00 | 50                | 50             | 1.000          | 50             |
| 10.10.20.42 | 2026-02-04 01:30:00 | 50                | 50             | 1.000          | 50             |
| 10.10.20.42 | 2026-02-04 01:45:00 | 50                | 50             | 1.000          | 50             |

| src_ip      | time_bin            | total_dns_queries | nxdomain_count | nxdomain_ratio | unique_queries |
|-------------|---------------------|-------------------|----------------|----------------|----------------|
| 10.10.20.42 | 2026-02-04 02:00:00 | 50                | 50             | 1.000          | 50             |
| 10.10.20.42 | 2026-02-04 02:15:00 | 43                | 43             | 1.000          | 43             |
| 10.10.20.42 | 2026-02-04 01:00:00 | 18                | 17             | 0.944          | 18             |

The pattern is striking in its consistency: in four consecutive 15-minute windows (01:15 through 02:00), WS-033 generated exactly 50 unique NXDOMAIN queries per window — every single query failed. The rate of approximately one query every 18 seconds, sustained across 77 minutes, and the complete uniqueness of every queried domain (260 unique domains, zero repeated) are collectively inconsistent with any legitimate DNS activity pattern.

### Deep Analysis: WS-033 DGA Profile

| Metric                    | Value                                                   | Interpretation                                         |
|---------------------------|---------------------------------------------------------|--------------------------------------------------------|
| Source Host               | WS-033 (10.10.20.42)                                    | Enterprise workstation — user33                        |
| Activity Window           | 2026-02-04 01:00 – 02:27                                | 77-minute burst during off-hours (1 AM)                |
| Total NXDOMAIN Queries    | 260                                                     | Every query failed to resolve                          |
| Unique Domains Queried    | 260 / 260                                               | 100% unique — no domain was queried twice              |
| Sample Domains            | n3iyd2xmwa8xr.com, qqtkv8thqhh0r.com, 2zy6gcfo1smb7.com | Alphanumeric, no English words, variable length        |
| Query Rate                | ~3.4 queries/minute                                     | Systematic, automated pacing                           |
| Query Length (mean ± std) | 45.7 ± 14.6 chars                                       | Variable length consistent with algorithmic generation |
| Pre-burst DNS Behavior    | Normal (github.com, microsoft.com, zoom.us)             | No anomaly before 01:00 on 2026-02-04                  |
| Post-burst DNS Behavior   | Returns to normal                                       | Burst is a discrete event, not persistent              |
| rcode for all events      | NXDOMAIN                                                | None of the generated domains are registered/active    |

The temporal isolation of the burst — occurring exclusively between 01:00 and 02:27 on February 4, with completely normal DNS behavior on either side — is characteristic of a triggered or scheduled DGA execution. The off-hours timing (1 AM) reduces the likelihood of SOC analyst attention and reflects common adversary operational security practices. The fact that every domain was unique and every query failed suggests WS-033 was still in the infrastructure discovery phase — the active C2 servers had not yet

cycled to a domain within WS-033's current DGA seed window, or the implant was using a different DGA seed than the registered domains.

**Notable Observation:** Query length variance (std = 14.6 chars) with mean 45.7 chars is consistent with variable-length DGA output. Fixed-length DGA algorithms would show near-zero std. Variable-length suggests a more sophisticated DGA implementation.

Cross-Telemetry Correlation

Correlation Methodology

The assignment requires correlation across at least two telemetry sources. The primary correlation mechanism employed here is DNS answer IP matching: identifying DNS resolution events whose answer field matches a beacon destination IP, thereby establishing a named domain as the entry point into the C2 infrastructure.

WS-007 Correlation: DNS → Flow Beacon Chain

DNS telemetry confirms that host 10.10.20.16 (WS-007) resolved the domain vbx92-z8lq.com to the IP address 185.203.116.77 at exactly 09:15:00 on February 3, 2026. The first beacon flow to 185.203.116.77:443 was observed at 09:15:58 — 58 seconds after the DNS resolution. This latency is consistent with implant initialization: the malware resolves its C2 domain, establishes the first HTTPS connection, completes the initial check-in handshake, and then enters its periodic callback loop.

The domain vbx92-z8lq.com was queried exclusively by WS-007 across the entire 7-day observation window. No other host resolved this domain, which rules out a shared enterprise application or browser plugin as the query source. The domain structure itself — a 14-character alphanumeric string with a hyphen separator — is inconsistent with human-registered commercial domains and is consistent with programmatically generated or operationally assigned C2 infrastructure domains.

| Event            | Timestamp                           | Source | Telemetry | Detail                                                             |
|------------------|-------------------------------------|--------|-----------|--------------------------------------------------------------------|
| DNS Query        | 2026-02-03 09:15:00                 | WS-007 | DNS Log   | Query: vbx92-z8lq.com → Answer: 185.203.116.77 (NOERROR)           |
| First Beacon     | 2026-02-03 09:15:58                 | WS-007 | Flow Log  | TCP/443 to 185.203.116.77 — 58s after resolution                   |
| Beacon Sustained | 2026-02-03 09:16 – 2026-02-04 14:09 | WS-007 | Flow Log  | 1,600 connections, μ=65s, σ=6.2s                                   |
| DNS Repeated     | 2026-02-03 09:15 – 2026-02-04 14:09 | WS-007 | DNS Log   | 1,600 parallel DNS queries — likely re-resolution on each callback |
| Last Beacon      | 2026-02-04 14:09:20                 | WS-007 | Flow Log  | 28.9-hour continuous operation window ends                         |

WS-033 Contextual Correlation



While WS-033 (10.10.20.42) does not appear in the beaconing results — its DGA activity produced exclusively NXDOMAIN responses, meaning it never successfully connected to a C2 server — its behavioral pattern is an important part of the overall threat picture. WS-033 exhibited entirely normal DNS behavior (github.com, microsoft.com, zoom.us, canvaslms.com) during normal business hours on February 1–3, 2026. The sudden shift to 260 algorithmic domain queries at 01:00 AM on February 4 indicates a state change in the host — consistent with malware that was dormant during initial infection and activation.

The fact that WS-033's DGA burst overlaps temporally with WS-007's active beacon period (WS-007 was actively beaconing from Feb 3 09:15 through Feb 4 14:09) suggests both hosts may be part of the same campaign or operator infrastructure, potentially deployed via the same initial access vector. WS-033 may have been compromised by WS-007's implant performing lateral movement, or both may have been compromised via a shared phishing or watering hole event.

### Consolidated Attack Timeline

| Timestamp                           | Host   | Event                                         | Telemetry Source | Significance                                                      |
|-------------------------------------|--------|-----------------------------------------------|------------------|-------------------------------------------------------------------|
| 2026-02-03 09:15:00                 | WS-007 | Resolves vbx92-z8lq.com → 185.203.116.77      | DNS              | Initial C2 domain resolution — implant activates                  |
| 2026-02-03 09:15:58                 | WS-007 | First outbound beacon to 185.203.116.77:443   | Flow             | C2 channel established — implant online                           |
| 2026-02-03 09:15 – 2026-02-04 14:09 | WS-007 | 1,600 periodic check-ins (65s interval)       | Flow + DNS       | Active C2 operation over 28.9 hours                               |
| 2026-02-04 01:00:00                 | WS-033 | DGA burst begins — NXDOMAIN queries start     | DNS              | Second implant activates, begins C2 discovery                     |
| 2026-02-04 01:00 – 02:27            | WS-033 | 260 unique NXDOMAIN queries across 77 minutes | DNS              | DGA iterating — no active C2 domain found                         |
| 2026-02-04 02:27:00                 | WS-033 | DGA burst ends — DNS returns to normal        | DNS              | DGA cycle exhausted or implant paused                             |
| 2026-02-04 14:09:20                 | WS-007 | Final beacon observed in dataset              | Flow             | Active window ends — infrastructure change or operator disconnect |



## Additional Telemetry for Attribution Strengthening

Behavioral correlation produces analytical reasoning, not proof of compromise. The following additional telemetry sources would materially strengthen attribution:

- TLS metadata & JA3/JA3S fingerprints: The JA3 hash of the TLS ClientHello from WS-007 to 185.203.116.77 would identify the C2 framework. Known frameworks (Cobalt Strike, Sliver, Metasploit) have published JA3 fingerprints.
- Endpoint telemetry (EDR/Sysmon): Process-level visibility would identify which executable on WS-007 is making the outbound connections. A system process (svchost, explorer) spawning unexpected HTTPS connections is a high-confidence indicator.
- Certificate transparency logs: The TLS certificate presented by 185.203.116.77 may appear in CT logs and reveal additional domains or infrastructure associations.
- WHOIS & passive DNS: Registration date of vbx92-z8lq.com — a recently registered domain with privacy-shielded WHOIS is a strong IOC in the context of this behavioral case.
- NetFlow / IPFIX for WS-033: Full flow data around the DGA burst would reveal whether WS-033 made any successful outbound TCP connections before or after the DNS burst, which would indicate C2 resolution through a different mechanism (hardcoded IP, domain fronting).

---

## Behavioral Modeling

### Why This Qualifies as Behavioral Detection

Traditional intrusion detection operates on pattern matching: compare observed traffic against a library of known-bad indicators IP addresses, domain names, file hashes, byte sequences. This approach is fundamentally reactive. Adversaries subvert it by rotating infrastructure faster than defenders can update signature libraries. A C2 operator can register a new domain, spin up a new VPS, and redirect all active implants in under an hour. Every signature becomes stale the moment the adversary rotates.

Behavioral detection does not compare against what is known to be bad. It characterizes the statistical properties of observed activity and identifies deviation from what is expected to be normal. The beaconing model presented here never queries a threat intelligence feed. It derives suspicion from two mathematical properties: the regularity of connection timing (low  $\sigma$ ) and the persistence of that regularity over time (high connection\_count). A human browsing the web to 185.203.116.77 would produce highly variable inter-arrival times. Software on a sleep timer cannot avoid regularity — it is a fundamental property of deterministic computation.

Similarly, the NXDOMAIN model never evaluates the semantic content of queried domains. It measures the statistical properties of resolution outcomes — the proportion of failures within a bounded time window and identifies when that proportion deviates dramatically from baseline expectations. The model would flag DGA activity even for a DGA variant that had never been observed before, because the behavioral signature (bulk failures, unique domains, algorithmic naming patterns) is preserved across DGA families.

### How attackers could evade your beacon model

A sophisticated adversary aware of statistical detection would attempt to corrupt the timing signal:

- **Jitter injection:** Adding randomized sleep offsets (e.g.,  $\pm 50\%$  of the base interval) increases  $\sigma$  substantially. A 60-second beacon with  $\pm 30s$  uniform jitter produces  $\sigma \approx 17s$  and  $CoV \approx 28\%$  — still below the 30s threshold. To evade the current model, an adversary needs  $\sigma > 30s$ , requiring  $\pm 46\%$  jitter on a 65s beacon. Some C2 frameworks support configurable jitter (Cobalt Strike malleable C2, Havoc beacon settings). Countermeasure: reduce the `std_delta` threshold progressively as operational FP data is collected, or add a CoV-based secondary filter.
- **Long-sleep beacons:** Increasing the check-in interval beyond 3600 seconds (hourly or less frequent) evades the `max_mean_delta` filter. Detection of low-frequency beacons requires longer observation windows and may need minimum-connection thresholds to be lowered. Countermeasure: add a separate slow-beacon detector with relaxed timing thresholds but stricter byte-size consistency requirements.
- **Traffic blending:** Mimicking the timing profile of a known legitimate service (e.g., Windows Update checking every 60 seconds) is theoretically possible but requires precise knowledge of the target baseline. Countermeasure: group-based baselining using historical traffic profiles to flag groups that are new or anomalous relative to their historical behavior.
- **Encrypted high-volume cover traffic:** Some C2 frameworks pad beacon traffic with randomized byte volumes to defeat size-based correlation. The current model uses timing as the primary signal, not volume, so this evasion does not apply — but it does limit enrichment of the detection with byte-volume consistency as a secondary signal.

## How attackers could evade your NXDOMAIN model

- **Rate limiting / slow DGA:** Spacing queries to one per several minutes keeps per-window counts below the minimum threshold. Countermeasure: widen the time window (e.g., 1 hour) at the cost of increased false-positive risk from DNS misconfiguration events.
- **Ratio dilution:** Interspersing legitimate successful queries between DGA attempts reduces the `nxdomain_ratio`. For example, alternating one NXDOMAIN with one legitimate query produces `ratio = 0.5`, exactly at the threshold. An adversary using 2:1 dilution drops below 0.5. Countermeasure: lower the ratio threshold and increase the absolute `nxdomain_count` requirement.
- **DGA seeds synchronized with registrar:** If the operator pre-registers a small number of domains from the current DGA seed window, some queries will return NOERROR. This reduces both count and ratio. Countermeasure: flag high volumes of queries to newly registered domains regardless of NXDOMAIN status — requires domain age data from passive DNS.
- **DNS tunneling / DoH:** Switching to DNS-over-HTTPS bypasses network-layer DNS sensors entirely. This is a fundamental architectural blind spot. Countermeasure: endpoint-level DNS interception or DNS-over-HTTPS blocking at the perimeter.

## False Positive Analysis

| Detection | False Positive Source       | Mechanism                                                              | Mitigation                                                                                  |
|-----------|-----------------------------|------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| Beaconing | Windows Update / SCCM agent | Periodic check-in to Microsoft update servers on a consistent schedule | Allowlist known internal management endpoints; normalize against historical group baselines |

| Detection | False Positive Source                         | Mechanism                                                                                | Mitigation                                                                                                     |
|-----------|-----------------------------------------------|------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------|
| Beaconing | NTP synchronization daemon                    | Periodic time queries to NTP pool servers                                                | Filter by dst_port 123 (NTP) or by known NTP server IPs                                                        |
| Beaconing | Monitoring agents (Zabbix, PRTG, CrowdStrike) | Security and monitoring tools maintain heartbeat connections                             | Build an approved-process baseline; correlate beacon src_ip with known agent deployments                       |
| Beaconing | Video conferencing (Zoom, Teams)              | Keep-alive packets on established sessions                                               | These typically have variable payload sizes and shorter durations; byte consistency filter helps differentiate |
| NXDOMAIN  | Domain migration / CDN change                 | Applications referencing old CDNs generate bursts of failures during DNS TTL propagation | Short duration (minutes, not hours); typically affects multiple src_ips simultaneously                         |
| NXDOMAIN  | Misconfigured DNS search suffix               | Missing search domain causes legitimate short-name queries to fail                       | Queries contain non-FQDN patterns; filter by query_len or presence of dots                                     |
| NXDOMAIN  | Browser NXDOMAIN probe                        | Some browsers probe for non-existent domains to detect captive portals                   | Very low count (<5), easily filtered by minimum count threshold                                                |

## SOC Integration Considerations

The detection logic described in this report is designed to function as a candidate generation engine within a broader SOC triage workflow, not as an autonomous decision system. Detection produces candidate hosts and sessions for human analyst review, not automated blocking actions.

In a production SOC pipeline, the outputs of these two detection models — beacon\_candidates and nxdomain\_candidates — would be enriched with additional context before analyst assignment: reverse DNS lookup on the destination IP, passive DNS history for the queried domain, asset inventory lookup to identify the owner and function of the source host, and SIEM alert correlation to check for prior incidents involving these assets. The combined output would be scored and prioritized, with correlated findings (hosts appearing in both detections, or hosts where DNS and flow data tell a consistent story) receiving elevated priority.

The detection logic would be deployed as a scheduled batch job or streaming analytics pipeline depending on the SIEM platform. Detection latency is a function of the minimum connection\_count threshold — at 20 connections with a 65-second interval, a beacon must operate for approximately 22 minutes before generating an alert. This is an acceptable latency for threat hunting workflows. For real-time alerting, a lower initial threshold (e.g., 10 connections) with elevated uncertainty could trigger earlier analyst engagement.

## Architectural Reflection (HW3 Sensor Placement)

## What the Sensor Placement Enabled

---

The detections described in this report were made possible by specific sensor placement decisions:

- **Boundary flow sensor:** Placement at the enterprise perimeter, between the internal user VLAN (10.10.20.0/24) and the upstream internet gateway, enabled visibility into all outbound connections from WS-007 to the external C2 IP 185.203.116.77. Without a perimeter sensor, this traffic would be invisible unless east-west sensors were deployed at every VLAN boundary.
- **Centralized DNS sensor:** Placement at the recursive resolver (or a tap on the DNS forwarder) provided complete DNS telemetry for all internal hosts. This enabled both the NXDOMAIN burst detection on WS-033 and the DNS-to-flow correlation linking vbx92-z8lq.com to 185.203.116.77.
- **VLAN visibility:** The flows.csv dataset contains traffic from 46 unique source IPs across the 10.10.20.0/24 range, indicating that the boundary sensor had full visibility into the user workstation VLAN. This is consistent with a sensor placed at the VLAN uplink rather than individual switch ports.

## Architectural Blind Spots

Several meaningful gaps exist in the current sensor architecture:

- **Encrypted payload content:** The beaconing detection was performed exclusively on flow metadata (connection timing, byte volumes). The actual payload content of the WS-007 to 185.203.116.77 HTTPS sessions is invisible. Any commands transmitted, data exfiltrated, or implant configuration updates exchanged cannot be observed without TLS inspection capability at the perimeter — which introduces its own operational and legal complexities in enterprise environments.
- **East-west (lateral movement) traffic:** The current sensor architecture captures egress traffic well, but internal host-to-host communications (e.g., WS-007 communicating with WS-033 if they are on the same VLAN) may not be visible without sensors at internal switch aggregation points. If WS-007 was used as a beachhead to deliver an implant to WS-033, that lateral movement channel is likely invisible in the current dataset.
- **DNS-over-HTTPS (DoH):** WS-033's DGA activity was only detectable because it used the enterprise DNS resolver, which was visible to the sensor. If the implant had been configured to use a DoH provider (Cloudflare 1.1.1.1, Google 8.8.8.8), the DNS queries would appear as encrypted HTTPS traffic to external IPs, completely bypassing network-layer DNS telemetry.
- **RDP traffic (TCP/3389):** The flow dataset contains 1,091 RDP connections from internal hosts. Without visibility into the RDP session content or source/destination relationships, it is impossible to determine whether any of this represents legitimate remote access or attacker lateral movement using compromised credentials.
- **Internal VLAN-to-VLAN traffic:** Traffic between the user VLAN (10.10.20.0/24) and the server VLAN (10.10.10.0/24) is visible in the dataset (AD/SMB traffic to 10.10.10.x), suggesting inter-VLAN routing visibility exists. However, traffic between hosts within the same VLAN (switched at Layer 2) may not reach the sensor depending on its placement relative to the distribution switch.

## Sensor Enhancement Recommendations

| Recommended Addition                  | Detection Value                                                                    | Implementation Consideration                                                    |
|---------------------------------------|------------------------------------------------------------------------------------|---------------------------------------------------------------------------------|
| TLS inspection (SSL bump)             | Decrypt and inspect C2 session content; JA3 fingerprinting; certificate validation | Legal/privacy review required; performance impact; cert deployment to endpoints |
| Internal east-west sensor (VLAN span) | Lateral movement detection; internal recon visibility; SMB anomalies               | High traffic volume; requires packet broker for scale                           |
| Endpoint DNS telemetry (Sysmon/EDR)   | DoH bypass detection; process-to-DNS correlation; per-process anomaly detection    | EDR agent deployment; endpoint performance impact                               |
| NetFlow/IPFIX on core switches        | Full connection visibility regardless of encryption; volume analysis               | Storage requirements; additional analysis infrastructure                        |
| Passive DNS caching                   | New domain detection; domain age correlation; registration anomaly analysis        | Requires integration with passive DNS provider or internal SOA logging          |

## Conclusion

This behavioral detection exercise demonstrates that statistically robust detection of C2 activity is achievable from raw telemetry without any reliance on threat intelligence, signatures, or known-bad indicators. The two behavioral models implemented inter-arrival time analysis for beaconing and windowed NXDOMAIN ratio analysis for DNS anomalies correctly identified two candidate hosts exhibiting patterns that are inconsistent with normal enterprise network behavior and consistent with active malware operation.

WS-007 (10.10.20.16) presents the most clear-cut behavioral case: 1,600 outbound HTTPS connections over 28.9 hours with a coefficient of variation of 9.5% in connection timing, preceded by DNS resolution of an algorithmically-named external domain to a non-enterprise IP address. WS-033 (10.10.20.42) presents a complementary case: a 77-minute burst of 260 unique NXDOMAIN queries during off-hours, with domain names exhibiting DGA-consistent patterns and no successful resolutions.

The correlation between DNS and flow telemetry provides the strongest analytical foundation: the temporal sequence of domain resolution followed by immediate connection initiation, the exclusive querying of vbx92-z8lq.com from a single host, and the 28.9-hour persistence of the resulting beacon channel together constitute a defensible behavioral case for analyst escalation. This demonstrates that behavioral detection, despite operating without adversary-specific knowledge, can produce actionable intelligence when telemetry is properly aggregated and statistically modeled.

The limitations of this analysis absence of TLS content inspection, potential east-west blind spots, DoH bypass risk, and lack of endpoint process correlation highlight both the value of multi-source telemetry integration and the inherent constraints of network-layer-only detection. A mature detection engineering program builds behavioral models across all available telemetry layers, not as isolated detectors but as an integrated analytical pipeline where each layer reduces the uncertainty introduced by the others.

**Analyst Recommendation:** WS-007 (10.10.20.16) and WS-033 (10.10.20.42) should be escalated to incident response for immediate endpoint investigation. WS-007 should be prioritized due to confirmed active C2 channel. Network isolation of both hosts is recommended pending forensic analysis.

## Appendix A — Detection Summary Tables

### A.1 Beacon Detection Output (Required Schema)

| src_ip      | dst_ip         | dst_port | connection_count | mean_delta_seconds | std_delta_seconds |
|-------------|----------------|----------|------------------|--------------------|-------------------|
| 10.10.20.16 | 185.203.116.77 | 443      | 1600             | 65.042             | 6.184             |

### A.2 NXDOMAIN Burst Detection Output (Required Schema)

| src_ip      | time_bin            | total_dns_queries | nxdomain_count | nxdomain_ratio | unique_queries |
|-------------|---------------------|-------------------|----------------|----------------|----------------|
| 10.10.20.42 | 2026-02-04 01:15:00 | 50                | 50             | 1.000          | 50             |
| 10.10.20.42 | 2026-02-04 01:30:00 | 50                | 50             | 1.000          | 50             |
| 10.10.20.42 | 2026-02-04 01:45:00 | 50                | 50             | 1.000          | 50             |
| 10.10.20.42 | 2026-02-04 02:00:00 | 50                | 50             | 1.000          | 50             |
| 10.10.20.42 | 2026-02-04 02:15:00 | 43                | 43             | 1.000          | 43             |
| 10.10.20.42 | 2026-02-04 01:00:00 | 18                | 17             | 0.944          | 18             |

### A.3 Threshold Configuration Summary

| Detection Model | Parameter              | Value | Justification                                 |
|-----------------|------------------------|-------|-----------------------------------------------|
| Beaconing       | min_connection_count   | 20    | Statistical stability; 22 min at 65s interval |
| Beaconing       | max_std_delta_seconds  | 30.0  | Captures beacons with up to $\pm 46\%$ jitter |
| Beaconing       | max_mean_delta_seconds | 3600  | Focus on sub-hourly C2 patterns               |
| NXDOMAIN        | min_total_dns_queries  | 10    | Volume floor to eliminate isolated failures   |
| NXDOMAIN        | min_nxdomain_count     | 5     | Absolute count prevents ratio inflation       |

| Detection Model | Parameter          | Value      | Justification                                |
|-----------------|--------------------|------------|----------------------------------------------|
| NXDOMAIN        | min_nxdomain_ratio | 0.50       | Majority-failure threshold for anomaly flag  |
| NXDOMAIN        | window_size        | 15 minutes | Balances sensitivity vs. false positive rate |